

Data Protection Impact Assessments (DPIAs)

Introduction

This document pulls in incorporates definitions and guidance from the Information Commissioner's Office (<https://ico.org.uk/>) Data Protection Commission of Ireland (<https://www.dataprotection.ie/>), the European Data Protection Board and the French Commission Nationale de l'Informatique et des Libertés (<https://www.cnil.fr/>) in addition to the risk-based approach that Data Protection Education takes in all our project and processing assessments.

Approach

The applied to DPE and the Record of processing

CNIL methodology	DPE Approach
The compliance approach implemented by carrying out a PIA is based on two pillars: ● fundamental rights and principles, which are “non-negotiable”, established by law and which must be respected, regardless of the nature, severity and likelihood of risks; ● management of data subjects’ privacy risks, which determines the appropriate technical and organisational controls to protect personal data. To summarise, to carry out a PIA it is necessary to: 1. define and describe the context of the processing of personal data under consideration; 2. analyse the controls guaranteeing compliance with the fundamental principles: the proportionality and necessity of processing, and the protection of data subjects' rights; 3. assess privacy risks associated with data security and ensure they are properly treated; 4. formally document the validation of the PIA in view of the previous facts to hand or decide to revise the previous steps.	The DPIA will be completed in the Knowledge Record of Processing tool. This provides an option for existing as well as new/proposed systems and processed. Many requirements of a DPIA are similar to the RoP process - understanding context and the analysis of what happens to the data and the controls (operational, technical and legal) that apply to it. These can all be documented in the RoP once, rather than been done multiple times. It also means that once a process for a new system is approved, then the DPIA becomes the record of that processing activity without any additional input. Each of the DPIA areas and how to complete a DPIA on the Knowledge Bank are below.

This is a continuous improvement process. Therefore, it sometimes requires several iterations to achieve an acceptable privacy protection system. It also requires a monitoring of changes over time (in context, controls, risks, etc.), for example, every year, and updates whenever a significant change occurs.

The approach should be implemented as soon as a new processing of personal data is designed. Implementing this approach at the outset makes it possible to determine the necessary and sufficient controls and thus to optimise costs. Conversely, implementing it after the creation of the system and the implementation of controls may call into question the choices made.

1. Study of the context

1.1 Overview

- Present a brief outline of the processing under consideration, its nature, scope, context, purposes and stakes.
 - Identify the data controller and any processors.
 - List the references applicable to the processing, which are necessary or must be complied with, not least the approved codes of conduct (see Art. 40 of the GDPR) and certifications regarding data protection (see Art. 42 of the GDPR)
- The outline is provided in the "Description" tab of the RoP
 - The data controller is the organisation completing the record
 - Codes of conduct and certifications can be added in the "Legal & Summary" tab. The "Legal & Summary" tab would usually be completed by the DPO.

1.2 Data, processes and supporting assets

- Define and describe the scope in detail:
 - the personal data concerned, their recipients and storage durations;
 - description of the processes and personal data supporting assets for the entire personal data life cycle (from collection to erasure).

Personal data and recipients are listed on the "Description" and "Data Flow" tabs.

- Retention is listed on the "Legal & Summary" tab
- Processes and supporting assets are in the "Data Flow" tabs and supporting master lists for third parties, hardware and software.

2. Study of the fundamental principles

2.1 Assessment of the controls guaranteeing the proportionality and necessity of the processing

- Explain and justify the choices made to comply with the following requirements:
 - a. purpose(s): specified, explicit and legitimate (see Art. 5.1 (b) of the GDPR);
 - b. basis: lawfulness of processing, prohibition of misuse (see Art. 6 of the GDPR)¹¹;
 - c. data minimisation: adequate, relevant and limited (see Art. 5 (c) of the GDPR)¹²;
 - d. quality of data: accurate and kept up-to-date (see Art. 5 (d) of the GDPR);
 - e. storage periods: limited (see Art. 5 (e) of the GDPR).

Controls are defined in numerous locations.

- Confirmation of adherence with data protection principles (Articles 5-11) are on the "Legal & Summary" tab
- Additional controls are identified in security measures in the "Data Flow" tab and in the hardware and software masterlists
 - Comments can be added in relation to the data protection principles.

- Check that improving the way in which each point is planned, clarified and justified, pursuant to the GDPR, is either not necessary or not possible.
- Where applicable, review their description or propose additional controls.

2.2 Assessment of controls protecting data subjects' rights

- Identify or determine, and describe, the controls (existing or planned) selected to comply with the following legal requirements (it is necessary to explain how it is intended to implement them):
 - information for the data subjects (fair and transparent processing, see Art. 12, 13 and 14 of the GDPR);
 - obtaining consent, where applicable¹³: express, can be demonstrated and withdrawn (see Art. 7 and 8 of the GDPR);
 - exercising the right of access and right to data portability (see Art. 15 and 20 of the GDPR);
 - exercising the rights to rectification and erasure (see Art. 16 and 17 of the GDPR);
 - exercising the right to restriction of processing and right to object (see Art. 18 and 21 of the GDPR);
 - processors: identified and governed by a contract (see Art. 28 of the GDPR);
 - transfers: compliance with the obligations bearing on transfer of data outside the European Union (see Art. 44 to 49 of the GDPR).
- Check that improving each control and its description, pursuant to the GDPR, is either not necessary or not possible.
- Where applicable, review their description or propose additional controls.

- Issues of necessity of processing should be added as a risk type in the "Risk" tab ("unnecessary processing") with mitigating action

The following details can be added in the "Legal & Summary" tab:

- What data subject rights are supported through policies and logs.
 - Comments can be added
 - Lawful basis (including consent) and how it is documented
 - Processors are listed in the "Data Flow" tab and third-party baseline assessments can be completed in the third-party masterlist
- Safeguards for international data transfers are documented in the "Legal & Summary" tab
- Breaches of data subject rights should be treated as a risk type under the "Risk" tab with mitigating action
- Issues of necessity of processing should be added as a risk type in

the "Risk" tab ("unnecessary processing") with mitigating action

3. Study of the risks related to the security of data

What is a privacy risk?

A risk is a hypothetical scenario that describes a feared event (uncertainty) and all the threats that would allow this to occur. More specifically, it describes:

- How risk sources (e.g.: an employee bribed by a competitor) could exploit the vulnerabilities of supporting assets (e.g.: the file management system that allows the manipulation of data)
- The context of the threat (e.g.: misuse by sending emails)
- How feared events may occur (e.g.: illegitimate access to personal data)
- Specifically, in relation to personal data (e.g.: customer file)

Thus, generating impacts on the privacy of data subjects (e.g.: unwanted solicitations, feelings of invasion of privacy, personal or professional problems).

Multiple risks can be documented under the "Risk" tab. We recommend that the risk assessment is conducted by, or in conjunction with the DPO.

Risks are associated with a specific data flow (the risk source/specific data), then the following identified:

- Type of data risk (context/how the risk event may occur)
- Level of data subject identification (to identify the level of personal data risk involved)

The risk level is estimated in terms of severity and likelihood:

- severity represents the magnitude of a risk. It primarily depends on the prejudicial nature of the potential impacts;
- likelihood expresses the possibility of a risk occurring. It primarily depends on the level of vulnerabilities of the supporting assets when under threat and the level of capabilities of the risk sources to exploit them.

a. Assessment of existing or planned controls

- Identify or determine the existing or planned controls (already undertaken), which can take three different forms:
 - controls bearing specifically on the data being processed: encryption, anonymization, partitioning, access control, traceability, etc.;
 - general security controls regarding the system in which the processing is carried out: operating security, backups, hardware security, etc.;
 - organizational controls (governance): policy, project management, personnel management, management of incidents and breaches, relations with third parties, etc.
- Check that improving each control and its description, pursuant to best security practices, is either not necessary or not possible.
- Where applicable, review their description or propose additional controls.

Assessment of severity and likelihood are all logged as well as any mitigating actions.

- Controls specific to the data being processed are identified in the "Description" (data classification) and "Data Flow" (system security) tabs
- General security controls are listed in the software and hardware masterlists
- Organisation controls are listed in the "Legal & Summary" tab (policies, logs supporting data rights, the Third-party masterlist (assessment of compliance) and personnel in the "People" tab (proficiencies)
- Issues should be added as a risk type in the "Risk" tab ("inadequate controls") with mitigating action

b. Risk assessment: potential privacy breaches

- For each feared event (illegitimate access to personal data, unwanted change of personal data, and disappearance of personal data):
 - determine the potential impacts on the data subjects' privacy if it occurred;
 - estimate its severity, particularly depending on the prejudicial nature of the potential impacts and, where applicable, controls likely to modify them;
 - identify the threats to personal data supporting assets that could lead to this feared event and the risk sources that could cause it;
 - estimate its likelihood, particularly depending on the level of vulnerabilities of personal data supporting assets, the level of capabilities of the risk sources to exploit them and the controls likely to modify them.
- Determine whether the risks identified in this way can be considered acceptable in view of the existing or planned controls.
- If not, propose additional controls and re-assess the level of each of the risks in view of the latter, so as to determine the residual risks.

Risk assessment is all completed within the "Risk" tab

- Impacts are identified
- Severity estimated (insignificant to catastrophic)
- Threats to assets are listed as specific risk types
- Likelihood estimated (never to almost certain)

Risk acceptability is decided using the mitigating action. The DPE risk assessment uses the five T's:

- Terminate (to stop the processing activity, or the data risk)
 - Tolerate (to accept the risk)
 - Transfer (usually through insurance)
 - Treat (reduce the identification, likelihood or severity)
- Take the opportunity (where the risk can be turned into project efficiency)

4. Validation of the PIA

a. Preparation of the material required for validation

- Consolidate and present the study's findings:
 - prepare a visual presentation of the controls selected to ensure compliance with the fundamental principles, depending on their compliance with the GDPR (e.g.: conditional on improvement or considered compliant);
 - prepare a visual presentation of the controls selected to contribute to data security, depending on their compliance with best security practices (e.g.: conditional on improvement or considered compliant);
 - visually map the risks (initial and residual where applicable²⁴) depending on their severity and likelihood;
 - draw up an action plan based on the additional controls identified during the previous steps: for each control, determine at least the person responsible for its implementation, its cost (financial or in terms of workload) and estimated timeframe.
- Formally document the consideration of stakeholders:
 - the advice of the person in charge of "Data Protection" aspects (see Art. 35 (2) of the GDPR);
 - the view of data subjects or their representatives (see Art. 35 (9) of the GDPR).

The RoP reporting tools will provide visual and formatted reports for various levels of risk reporting.

Stakeholders should be involved in new processes that may impact them.
Any reports can be uploaded in the "Legal & Summary" tab.

b. Formal validation ● Decide on whether the selected controls, residual risks and action plan are acceptable, with justifications, in light of the previously identified stakes and views of the stakeholders. In this way, the PIA may be: ○ validated; ○ conditional on improvement (explain in what way); ○ refused (along with the processing under consideration). ● Where necessary, repeat the previous steps so that the PIA can be validated.	The overall risk profile can be documented in the "Legal & Summary" tab. This should indicate the highest level of risk identified in any area of the process. The process status allows the validation of the process to be documented: ● In progress ● DPO review (when required) ● Refused (when DPO considers risk to high for process to continue, this is mostly used during the system design phase) ● Conditional upon improvement (when DPO considers additional work required, this is mostly used during the system design phase) ● Validated (When DPO considers new systems to have a satisfactory DPIA) ● Complete (a fully documented processing record for active systems and processes)
---	---